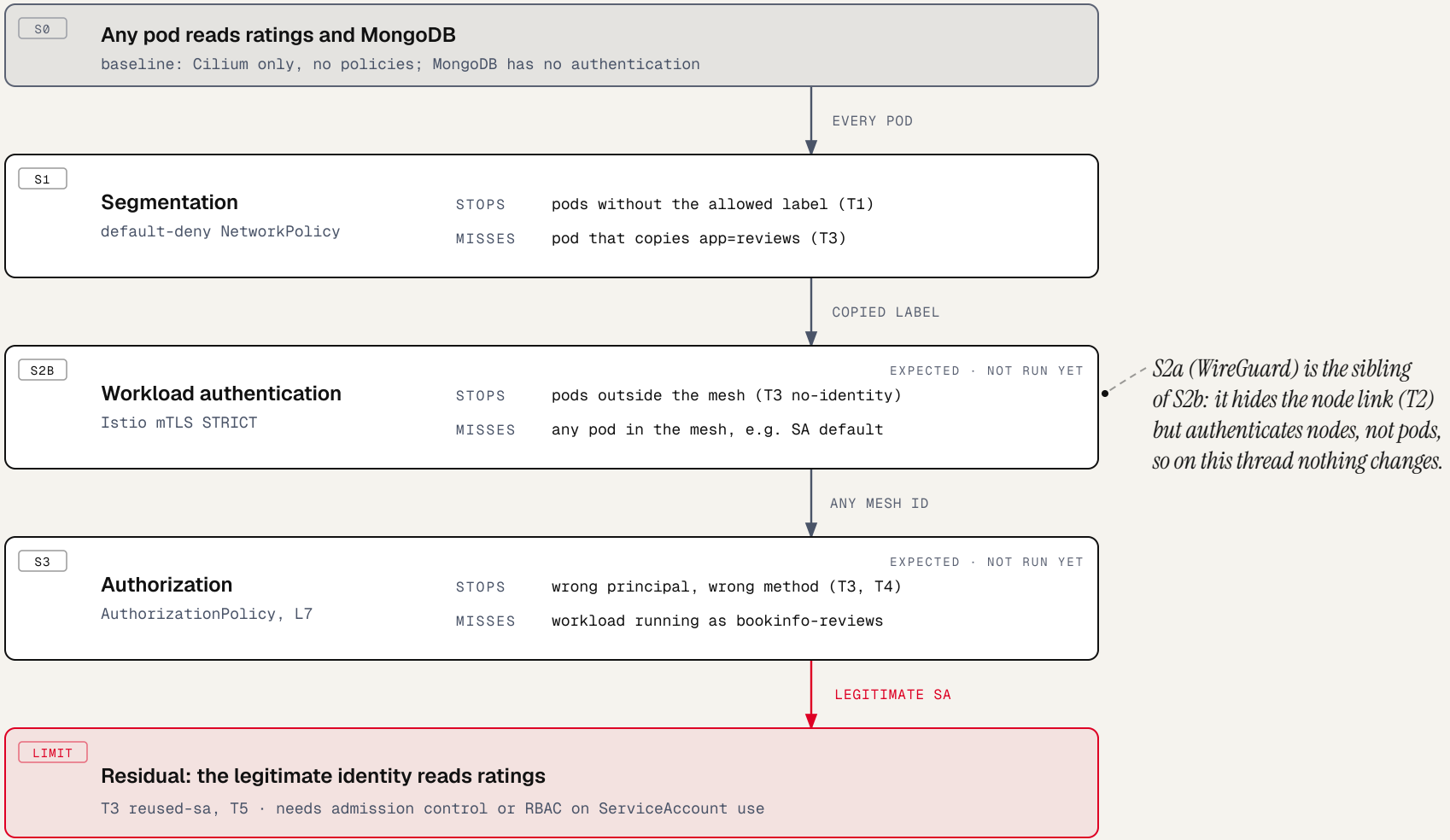

S0
Any pod reads ratings and MongoDB
baseline: Cilium only, no policies; MongoDB has no authentication
EVERY POD
S1
Segmentation
default-deny NetworkPolicy
STOPS
pods without the allowed label (T1)
MISSES
pod that copies app=reviews (T3)
COPIED LABEL
S2B
Workload authentication
Istio mTLS STRICT
EXPECTED · NOT RUN YET
STOPS
pods outside the mesh (T3 no-identity)
MISSES
any pod in the mesh, e.g. SA default
S2a (WireGuard) is the sibling of S2b: it hides the node link (T2) but authenticates nodes, not pods, so on this thread nothing changes.
ANY MESH ID
S3
Authorization
AuthorizationPolicy, L7
EXPECTED · NOT RUN YET
STOPS
wrong principal, wrong method (T3, T4)
MISSES
workload running as bookinfo-reviews
LEGITIMATE SA
LIMIT
Residual: the legitimate identity reads ratings
T3 reused-sa, T5 · needs admission control or RBAC on ServiceAccount use
LEGEND
control added by the scenario
what passes to the next layer
residual risk, not mitigated